

Tinker Tailor LLM Spy: Reconstructing "Deleted" Chats & Hijacking Sessions from Chromium LevelDB Caches

Proposal Info

Title:	Tinker Tailor LLM Spy: Reconstructing "Deleted" Chats & Hijacking Sessions from Chromium LevelDB Caches
Status:	Submitted / For Board Review
Session Type:	Briefings
Speaker:	Sapna (Lead Forensics Researcher, Verity Project)
Tracks:	AI, ML, & Data Science; Threat Hunting & Incident Response
Format:	40-Minute Briefings

Abstract

It's coming, and you aren't ready—your first forensic investigation involving Large Language Model (LLM) data leakage. GenAI portals (like ChatGPT, Claude, and Gemini) have become standard corporate utilities. To speed up workflows, developers and executives routinely copy and paste sensitive proprietary source code, internal configurations, and credentials into these clients. But when users click "Delete Chat" or clear histories, does that data actually get erased?

The truth is far more persistent. Chromium-based browsers (Google Chrome, Microsoft Edge) and native Electron desktop wrappers cache conversation telemetry inside client-side IndexedDB databases, which are backed by Google's LevelDB storage engine. Since LevelDB uses an append-only log-structured merge-tree (LSM tree), deleted records remain intact in write-ahead logs (.log) and uncompactd Sorted String Tables (.sst/.ldb) on local disks for days or weeks.

In this talk, we reveal the low-level serialization structures of client-side LLM databases and how to carve this "deleted" telemetry. We reverse engineer the V8 deserialization format (ValueSerializer), specifically dissecting V8 string tags (OneByteString vs TwoByteString UTF-16LE anomalies) and nested object boundary parsing. We introduce **Verity**, an open-source, zero-dependency python framework that dynamically sweeps all user profiles, bypasses active Windows file locks, and reconstructs deleted histories. Finally, we establish a cryptographically secured chain of custody using in-browser HMAC-SHA256 verification. Attendees will leave with a ready-to-use incident response playbook and the open-source Verity tool to audit and protect their organizations.

Presentation Outline – NOTE THE DETAILED OUTLINE

1. INTRODUCTION: THE EPHEMERAL AI FALLACY (5 mins)

- **The Mirage of Deletion:** Contrast cloud-side deletion logic with local disk remnants. Explain the LevelDB LSM-tree append-only structure.
- **Threat Modeling:** Assess how malicious actors, insider threats, and infostealer malware harvest unencrypted local browser caches to steal corporate intellectual property.
- **Target Mapping:** Location of IndexedDB LevelDB instances for ChatGPT, Claude, and Gemini on Windows AppData and macOS Library.

2. REVERSING CHROMIUM LEVELDB & STORAGE SCHEMA STRUCTURES (5 mins)

- **ChatGPT (Web & Desktop):** Layout of keys and IndexedDB schemas storing conversation content, model attributes, and temporary states.
- **Claude & Gemini:** Structural differences in LevelDB records, and mapping active workspace telemetry.
- **Session Credentials:** Identifying unencrypted session tokens (e.g. JWTs and session IDs) stored in IndexedDB that allow session hijacking.

3. ZERO-DEPENDENCY CARVING OF LEVELDB & COMPRESSED SSTABLES (10 mins)

- **Production Constrains:** Why native C++ leveldb drivers cannot be compiled/installed on endpoint machines during triage.
- **Pure-Python Parsers:** Building a pure-Python Protocol Buffer varint32 reader and block boundary parser.
- **Snappy Decompression:** Rebuilding a Snappy decompressor (literals and copy tags) in Python to extract compressed data blocks directly from SSTables.
- **Active Lock Bypass:** Opening write-ahead logs (.log) in read-only binary mode to clone records without tripping OS locks.

4. REBUILDING CONVERSATION TREES & DECODING V8 SERIALIZATION (10 mins)

- **V8 Deserialization format:** Decoding JavaScript serialized values.
- **String Anomalies:** Solving the OneByteString (ASCII) vs TwoByteString (UTF-16LE) tag length calculation byte bug.
- **Nesting & Boundaries:** Handling padding bytes and tracking nesting depth (object/array tags) to prevent premature parsing termination on 0x7b.
- **Role Math:** Mapping user vs assistant roles via Smi-shifted index keys and index parity:

```
role = "user" if (index / 2) mod 2 = 1 else "assistant"
```

- **Timeline Assembly:** Ordering chats using file modification times (mtime) and database byte offsets.

5. INCIDENT SCENARIO: THE INSIDER INTELLECTUAL PROPERTY EXFILTRATION (5 mins)

- **Scenario setup:** Developer pastes proprietary source code and API keys, deletes the chat, and clears browser history.
- **Forensic Acquisition:** Bypassing locks, cloning raw log files, and executing the Verity carver.

- **Reconstruction:** Demonstrating how the entire code block and thread context are recovered with zero-data loss.

6. INCIDENT SCENARIO: SESSION HIJACKING & FORENSIC INTEGRITY (5 mins)

- **The Session Takeover:** Extracting unencrypted session tokens from IndexedDB caches and hijacking the user's active session without entering credentials.
- **Chain of Custody:** Creating a tamper-proof forensic envelope by signing canonical JSON payloads using HMAC-SHA256.
- **Integrity Verification:** Validating signature seals in the dashboard using the Web Cryptography API.

7. CONCLUSION & MITIGATIONS (3 mins)

- **Key takeaways:** V8 deserialization, Snappy decompression, and browser multi-profile path audits.
- **Mitigations:** Implementing active cache eviction policies on logout, disk encryption (BitLocker), and EDR monitoring rules.
- **Open Source Release:** Announcing the public GitHub release of the Verity framework.

Questions & Answers

Is This Content New (Not Previously Presented/Published)?

Yes. While general SQLite/LevelDB structures are documented, the reverse engineering of client-side IndexedDB databases for LLM interfaces and the creation of a zero-dependency, pure-Python Snappy block carver for deleted data reconstruction is brand-new research.

Have You/Do You Plan to Submit This Talk to Another Conference?

No.

What new research, concept, technique, or approach is included in your submission?

1. **Low-Level V8 Forensics of GenAI Clients:** We document the client-side IndexedDB database schemas of ChatGPT, Claude, and Gemini, proving that cleared conversations remain on disk.
2. **Zero-Dependency Snappy/SSTable Carver:** We introduce a technique to parse LevelDB SSTables and decompress Snappy blocks entirely in memory using pure Python, eliminating compiled C++ dependencies.
3. **Dynamic Profile Sweeping & Lock Bypass:** Automatically identifies all active Chromium browser profiles and reads write-ahead logs in read-only mode to bypass OS file locks.

Provide 3 Audience Takeaways.

1. **AI Local Footprint Map:** Deep technical knowledge of where and how local AI client data is stored, and the specific database keys containing session credentials and chat logs.
2. **LevelDB V8 Carving Mechanics:** The ability to write compile-free scripts to parse Protocol Buffer varints, Snappy blocks, and V8 serialized strings from raw disk dumps.
3. **Open-Source Tooling:** Access to the open-source Verity tool to immediately audit endpoints and secure corporate AI workloads.

If applicable, what problem does your research solve?

Traditional EDR agents and forensic suites do not parse GenAI IndexedDB records. If sensitive intellectual property or active AI account credentials are leaked, incident responders lack playbooks to audit the breach. Verity solves this by providing a single-file, zero-dependency Python script that bypasses locks, extracts browser profiles, and compiles verified reports under a cryptographic chain of custody.

Will You Be Releasing a New Tool? If Yes, Describe the Tool.

Yes. We will be releasing **Verity**, an open-source, zero-dependency Python framework designed for incident responders. It automates the extraction and parsing of LLM databases (browser IndexedDB and desktop wrappers), handles live SQLite lock bypasses, performs process-to-socket audits, and outputs a clean forensic evidence report to JSON or a centralized web-based lab interface.

Is This a New Vulnerability? If Yes, Describe the Vulnerability.

Yes. While not a direct remote code execution exploit in Chromium, our research exposes two distinct local vulnerabilities that directly impact modern enterprise AI usage:

1. **Unprotected Local Session Credential Leakage in IndexedDB (Chrome/Edge):** Chromium-based browsers fail to apply OS-level cryptographic protections (like DPAPI or Keychain) to cookies and authorization tokens stored within IndexedDB LevelDB instances. Standard cookies and passwords are encrypted, but IndexedDB stores active LLM tokens in plaintext, enabling low-privilege processes or infostealers to hijack AI sessions.
2. **Forensic Leakage of Deleted Telemetry (LevelDB LSM-Tree Persistence):** LevelDB's append-only design means that clicking 'Delete Chat' in an LLM web UI does not purge the data from disk. It merely deletes the database index pointer. The actual chat messages, source code blocks, and sensitive credentials remain on-disk in write-ahead logs (.log) and uncompactd Sorted String Tables (.sst/.ldb) indefinitely. We show how these can be forensically reconstructed using raw byte carving.

Will Your Presentation Include a Demo? If Yes, Describe the Demo.

Yes. The presentation will include a pre-recorded demo video showing:

1. A developer pasting proprietary corporate source code into ChatGPT under Chrome Profile 3, and then deleting the conversation using the web interface.
2. The execution of the Verity script on the target workstation.
3. The dynamic discovery of Profile 3 databases and the instant forensic reassembly of the "deleted" code blocks by carving the LevelDB data files.
4. The extraction of active session tokens to hijack the developer's session, followed by the verification of the evidence integrity using the Web Cryptography API.

Provide the Names of the Speakers Presenting and Their Previous Speaking Experience.

Speaker: Sapna (Lead Forensics Researcher, Verity Project)

Speaking Experience: Regular presenter at local security meetups, DEF CON Groups, and contributor to open-source forensic tools. First-time speaker at Black Hat Briefings.

Does Your Company/ Employer Provide a Solution to the Issue Addressed? If Yes, Please Provide Details.

No.

Do You Want to Provide a White Paper for Review by the Board?

Yes. We will provide our comprehensive whitepaper detailing the exact binary layouts, Snappy decompression code, and timeline reassembly algorithms.